

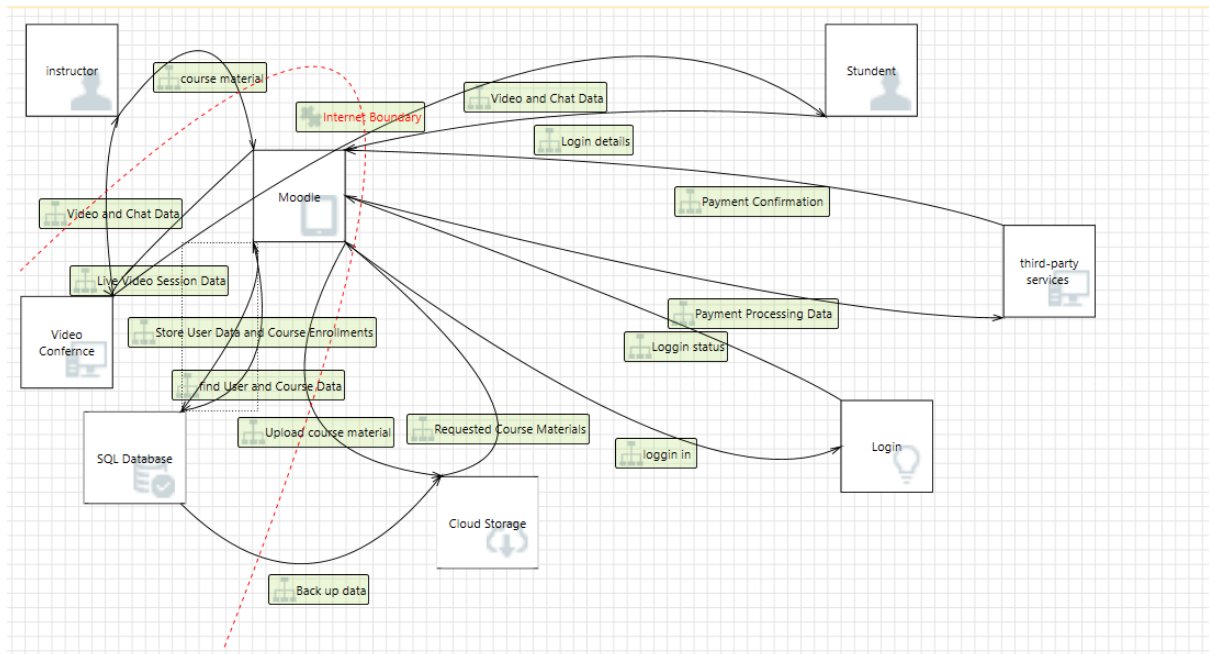
Application Security Assignment 2

B00144376

Introduction

This report will present a comprehensive Threat Model assessment for an online education platform called Moodle the platform enables Students to enrol in courses, access course materials, and interact with instructors via chat and video conferencing. This report will also explore the system to identify threats, document them, and propose mitigation strategies against them. The report will use Data Flow Diagrams to present how the system works and use STRIDE to Categorize the possible threats and develop a Dread to rank these threats. Additionally, I created an attack tree using draw.io to explore the major threats.

Level 0 DFD



Data Flow for DFD 0

Student provides information like name, email, and password payment details and requests for enrolment

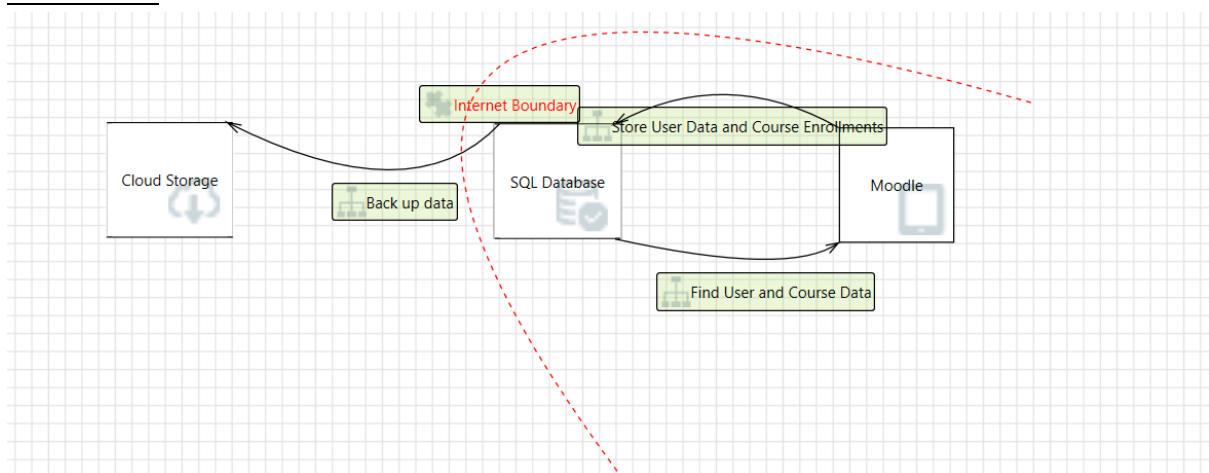
The platform then processes all the sent data and communicates with other services to set up the video session and the payment process.

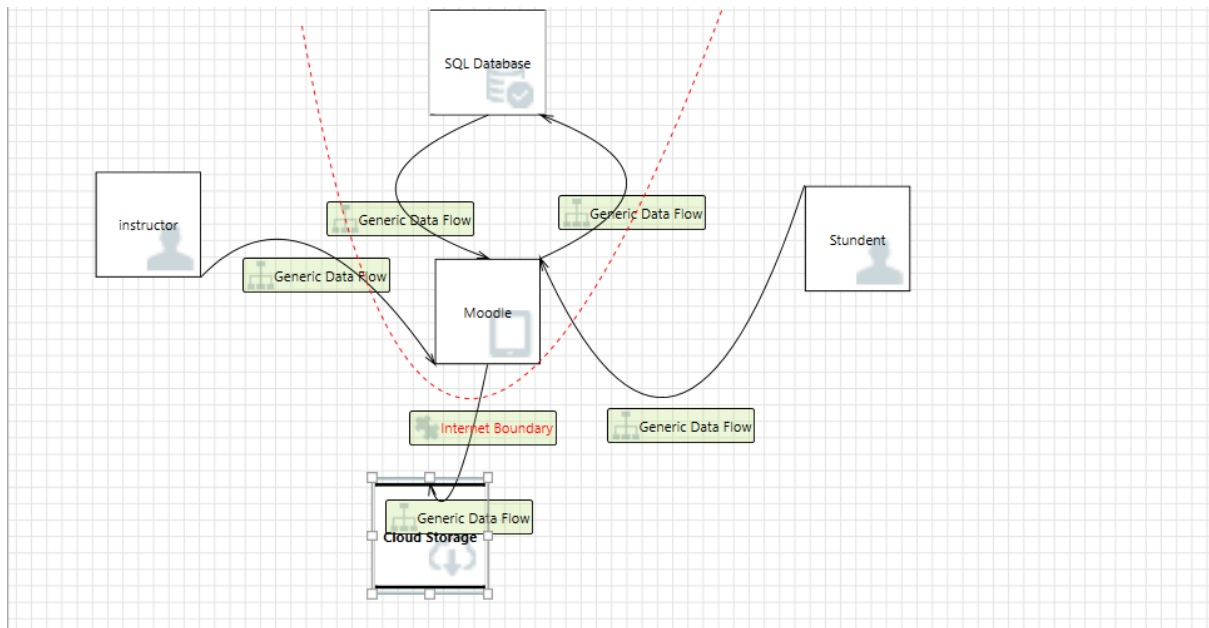
The student data is then stored in the SQL database and the cloud as a backup stored retrieve course materials as needed.

Trust boundaries

The trust boundaries are located between the and the third parties service this indicate were Vulnerabilities could be

Level 1 DFD





2

Stride

Instructor

Spoofing

Hackers may try to spoof the instructor's account to upload malware to students and the course

Tampering

Hackers could attempt to modify course materials

Denial of Service

Preventing the instructor from uploading content by flooding the system traffic

Moodle

Repudiation

Students/Instructor deny their interactions with the course hub.

Information Disclosure

Sensitive information like login details of video sessions being exposed by the attacker.

SQL Database

Information Disclosure

The attacker is exposing sensitive user information stored in the database.

Cloud Storage

Denial of Service

Attacker keeping backed-up files from being accessed by students/instructors.

Login System

Elevation of Privilege

Exploiting Vulnerabilities to Bypass Authentication#

Video Conference

Repudiation

Student/instructor Refusing to participate or take action during a session.

Third-Party Services

Spoofing

Attackers impersonate third-party payment systems to steal customer payments.

2.2

Dread Report

Threat 1

External Entity Course Hub Potentially Denies Receiving Data

CATEGORY: Repudiation

SHORT DESCRIPTION: Repudiation threats involve an adversary denying that something happened.

DESCRIPTION:

Moodle claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

JUSTIFICATION:

INTERACTION: course material

PRIORITY: High

Damage

A loss of accountability and trust can occur if Moodle can deny receiving data if Moodle is responsible for the processing and management of student and instructor data a Repudiation Can cause significant issues (7)

Reproducibility

If appropriate logging procedures are not in place Repudiation can be repeated easily simple configuration flaws or missing logging can allow this threat to be repeated each time data is received. (9)

Exploitability

If auditing and logging are not in place or are set up incorrectly repudiation can be exploited very easily especially if Moodle does not have proper logging or auditing in place to record received data. (8)

Affected user

This would affect all users Across the platform especially with Moodle Managing a large amount of course material and student data. (10)

Discoverability

Can be found easily especially if someone audits the system or reviews the logs (10)

Total dread Score

$$7 + 9 + 8 + 10 + 10 / 5 = 8.8$$

Mitigation Strategies

Logs

Implement robust logs that review records and timestamp all the data that is sent so it is impenetrable to tamper with.

Receipt Function Mechanisms

Implement a function that Moodle acknowledges receipt of data to the sender.

Threat 2

ID: 109

THREAT: Data Flow course material Is Potentially Interrupted

CATEGORY: Denial Of Service

SHORT DESCRIPTION: Denial of Service happens when the process or a datastore is not able to service incoming requests or perform up to spec.

DESCRIPTION:

An external agent interrupts data flowing across a trust boundary in either direction.

INTERACTION: course material

PRIORITY: High

DESCRIPTION:

An external agent interrupts data flowing across a trust boundary in either direction.

PRIORITY: High

Damage

This threat could cause serious disruption in educational processes by blocking access to vital resources, resulting in missed deadlines, or delaying learning. If the content is time-sensitive, like assignments or tests, the effects could be worse. (8)

Reproducibility

Not as complex to replicate an attack like this one. once the attack is found (5)

Exploitability

Require having the capacity to launch a DoS attack and access trust boundary points Resources and a moderate level of technical competence would be needed for this. (7)

Affected users

Affects all users due to the disruption of course materials (10)

Discoverability

Denial of service attacks Can be found out easily due to the attack being noticeably. (10)

DREAD Score Calculation

$$8 + 5 + 7 + 10 + 10/5 = 8$$

Mitigation Strategies

Monitoring

Implement a real-time monitoring system to spot odd traffic surges

Traffic Filtering

Use tools like Wireshark to analyze to detect and prevent potential DoS attacks.

ID: 114

DIAGRAM: Threat Modelling Education

STATE: Not Started

THREAT: Weakness in SSO Authorization

CATEGORY: Elevation Of Privilege

SHORT DESCRIPTION: A user subject gains increased capability or privilege by taking advantage of an implementation bug.

DESCRIPTION:

Common SSO implementations such as OAUTH2 and OAUTH Wrap are vulnerable to MitM attacks.

JUSTIFICATION:

INTERACTION: logging in

PRIORITY: High

Damage

The Damage result of this threat could lead to sensitive data being compromised and system integrity due to unauthorized access This might significantly affect system reliability and data confidentiality. (8)

Reproducibility

Reproducibility is not fully reproducible need specific circumstances, like an unprotected network or endpoints that aren't configured correctly. (7)

Exploitability

Attacker required to have a level of expertise and resources to accomplish exploitation (6)

Affected Users

Affects all users if password and session tokens are compromised (10)

Discoverability

Can not be found out easily due to attackers finding the implementation errors more easily (10)

DREAD Score Calculation

$$8 + 7 + 6 + 10 + 10 / 5 = 6.8$$

Mitigation Strategies

Secure Protocols

Use protocols like HTTPS to prevent token interception.

ID: 117

DIAGRAM: Threat Modelling Education

THREAT: Spoofing of Destination Data Store SQL Database

CATEGORY: Spoofing

SHORT DESCRIPTION: Spoofing occurs when a process or entity is something other than its claimed identity. Examples include substituting a process, a file, a website, or a network address.

DESCRIPTION:

SQL Database may be spoofed by an attacker, and this may lead to data being written to the attacker's target instead of the SQL Database. Consider using a standard authentication mechanism to identify the destination data store.

INTERACTION: Store User Data and Course Enrolments

PRIORITY: High

Damage

If spoofing is successful Sensitive data could be compromised and vital systems could be accessed without authorization big threat to reputation as System dependability, data integrity, and secrecy would all be greatly impacted. (9)

Reproducibility

Fully reproducible if the attacker gets access to open ports and misconfigured endpoints (10)

Exploitability

an attacker needs technical knowledge and resources moderately difficult to exploit without (6).

Affected Users

Affects all users if the breach of course enrollments, user data, and system functionality, which causes widespread destruction (10)

Discoverability

Can not be found easily due to as the spoofed database could appear to function normally for some time. (10)

DREAD Score Calculation

$$9 + 10 + 6 + 10 + 10/5 = 9$$

Mitigation Strategies

Access Restrictions

The usage of secure authentication tokens to help restrict unauthorized database access.

Monitoring

Do continuous monitoring for anomalies in the destinations of data transfers.

Threat 5

ID: 118

THREAT: Possible SQL Injection Vulnerability for SQL Database

CATEGORY: Tampering

SHORT DESCRIPTION: Tampering is the act of altering the bits. Tampering with a process involves changing bits in the running process. Similarly, tampering with a data flow involves changing bits on the wire or between two running processes.

DESCRIPTION:

SQL injection is an attack in which malicious code is inserted into strings that are later passed to an instance of SQL Server for parsing and execution. Any procedure that constructs SQL statements should be reviewed for injection vulnerabilities because SQL Server will execute all syntactically valid queries that it receives. Even parameterized data can be manipulated by a skilled and determined attacker.

INTERACTION: Store User Data and Course Enrollments

PRIORITY: High

Damage

If the SQL is injected the database could be compromised resulting in unauthorized access, data breaches, or the corruption of important data like user profiles and course enrolments. Threat to reputation as well as financial and legal liability

(8)

Reproducibility

Fully reproducible by attackers using the same tools and scripts

(10)

Exploitability

Understanding of the SQL Syntax is necessary for the attacker to exploit (7)

Affected users

Affects all users who depend on the database if user information and course enrollments are compromised or altered can cause disruption (10)

Discoverability

Can not be found out easily by using a systematic set of tests against every entry point in the application (10)

DREAD Score Calculation

$8+10+7+10+10/5=9$

Mitigation Strategies

Vulnerability Scan

Run frequent scans for SQL injection vulnerability

Input Validation

Review and validate all user inputs before processing them.

ID: 120

DIAGRAM: Threat Modelling Education

CHANGED BY:

<none provided>

LAST MODIFIED:

Generated

THREAT: Weak Access Control for a Resource

CATEGORY: Information Disclosure

SHORT DESCRIPTION: Information disclosure happens when the information can be read by an unauthorized party.

DESCRIPTION:

Improper data protection of SQL Database can allow an attacker to read information not intended for disclosure. Review authorization settings.

INTERACTION: find User and Course Data

PRIORITY: High

Damage

unauthorized access, to data. Has Threat to reputation as well as financial and legal liability

(8)

Reproducibility

Fully reproducible by attackers using the same tools and scripts

(10)

Exploitability

Understanding of the SQL Syntax is necessary for the attacker to exploit (7)

Affected users

Affects all users who depend on the database if user information and course enrollments are compromised or altered can cause disruption (10)

Discoverability

Can not be found out easily by using a systematic set of tests against every entry point in the application (10)

DREAD Score Calculation

$$8 + 10 + 7 + 10 + 10 / 5 = 9$$

Mitigation Strategies

Audits:

To Ensure the least-privilege principle is being followed audit access controls regularly.

ID:131

DIAGRAM: Threat Modelling Education

THREAT: External Entity third-party services Potentially Denies Receiving Data

CATEGORY: Repudiation

SHORT DESCRIPTION: Repudiation threats involve an adversary denying that something happened.

DESCRIPTION:

third-party services claim that they did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

INTERACTION: Payment Processing Data

PRIORITY: High

Damage

Financial liability could be at cost if there is denial in receipt Additionally, it can damage user trust and harm third-party partnerships. (8)

Reproducibility

Fully reproducible if third-party knows data receipt (10)

Exploitability

Requires having access to the communication process to exploit this threat (7)

Affected users

It affects all users who depend on the system for transactions (10)

Discoverability

Monitoring frequently identifies the threat (8)

DREAD Score Calculation

$$8+10+7+10+8/5 = 8.6$$

Mitigation Strategies

Logs

Implement robust logs that review records and timestamp all the data that is sent so it is impenetrable to tamper with.

ID:140

DIAGRAM: Threat Modelling Education

THREAT: Spoofing of Destination Data Store Cloud Storage

CATEGORY: Spoofing

SHORT DESCRIPTION: Spoofing occurs when a process or entity is something other than its claimed identity. Examples include substituting a process, a file, a website, or a network address.

DESCRIPTION:

An attacker may spoof Cloud Storage, which could lead to data being written to the attacker's target instead of Cloud Storage. Consider using a standard authentication mechanism to identify the destination data store.

INTERACTION: Back up data

PRIORITY: High

Damage

Data breaches unauthorized access, and data loss for backup data can occur due to cloud storage spoofing This may result in financial losses, harm to reputation, and non-compliance with data protection regulations. (8)

Reproducibility

Fully reproducible If the spoofing is not mitigated, the attacker can continuously intercept data transfers without being discovered. (10)

Exploitability

Requires having network access, an understanding of the data flow, and the ability to impersonate the legitimate cloud storage connection (6)

Affected users

It affects all users relying on cloud storage for backup comprised backup could lead to disruption (10)

Discoverability

If the attacker launched successfully, it could not be discovered for a long period (6)

DREAD Score Calculation

$$8+10+6+10+6/5= 8$$

Mitigation Strategies

Authentication

Implement robust authentication like the (MFA) protocol.

Encryption

encrypted before transmission to prevent interception

ID:137

DIAGRAM: Threat Modelling Education

THREAT: External Entity Student Potentially Denies Receiving Data

CATEGORY: Repudiation

SHORT DESCRIPTION: Repudiation threats involve an adversary denying that something happened.

DESCRIPTION:

The student claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

INTERACTION: Video and Chat Data

PRIORITY: High

Damage

If students deny that they did not receive video or chat data it could damage the platform's reputation, and even legal repercussions, especially if the data includes exchanges that are sensitive to compliance. (8)

Reproducibility

Fully reproducible if students continue denying that they did not receive any data, especially with no logging or acknowledgment system in place (10)

Exploitability

Does not Require to be on the same subnet or have compromised a route to be exploited (7)

Affected users

It affects all student users who rely on the system for video or chat interactions. (6)

Discoverability

Can not be easily found due to The absence of logging or acknowledgment mechanisms(8)

DREAD Score Calculation

$$8+10+7+6+8/5 = 7.8$$

Mitigation Strategies

Function for Acknowledgment:

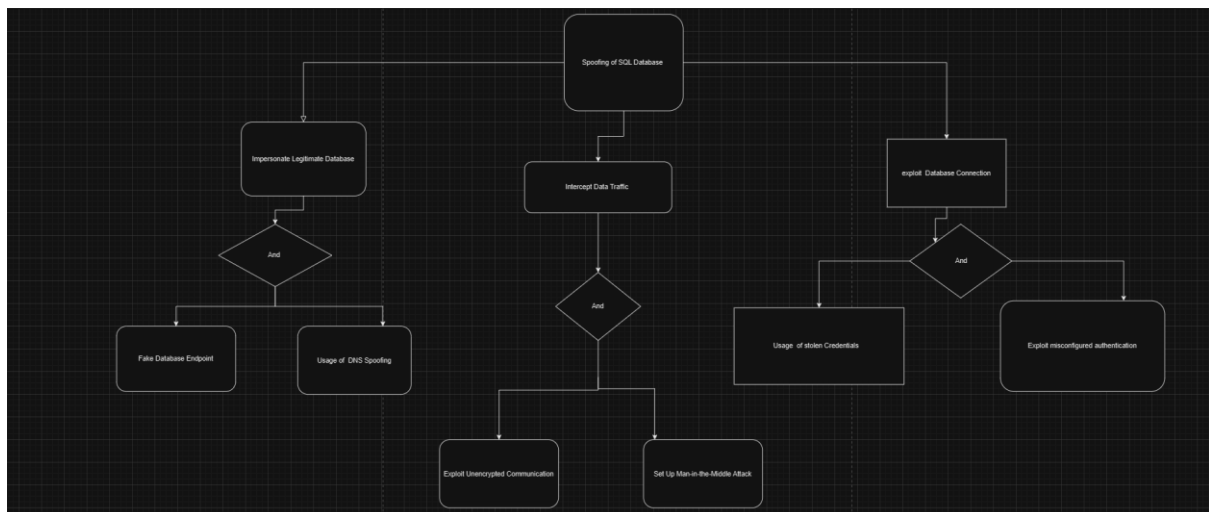
Demand that student users attest to receiving the data.

Logs

Implement robust logs that review records and timestamp all the data that is sent so it is impenetrable to tamper with.

3. Attack Tree

Spoofing of SQL Database



Dread Report

Branch 1: Impersonate Legitimate Database

Threat: Fake Database Endpoint

Damage

Threat to reputation if sensitive data is compromised, a huge amount of loss will occur. (8)

Reproducibility

Fully reproducible if an endpoint is identified spoofing can be easily automated. (10)

Exploitability

An attacker must know the tools and specialized knowledge to exploit the threat (6)

Affected Users

It affects all users that are relying on data (10)

Discoverability

To locate the endpoint reconnaissance is necessary (6)

DREAD Score Calculation

$$8+10+6+10+6/5 = 8$$

Branch 1: Impersonate Legitimate Database

Threat: Usage of DNS Spoofing

Damage

If traffic is redirected all data may be compromised which could lead to financial and legal liability. (8)

Reproducibility

The attacker must develop more on the attack to make it fully reproducible. (6)

Exploitability

An attacker have a level of skill to exploit the threat (7)

Affected Users

It affects all users that are relying on data (10)

Discoverability

reconnaissance is necessary (6)

DREAD Score Calculation

$$8+6+7+10+6/5 = 7.4$$

Branch 2: Intercept Data Traffic

Threat: Exploit Unencrypted Communication

Damage

Sensitive data can be exposed if communication is exploited and damages reputation. (8)

Reproducibility

If communication is encrypted, then the threat is fully reproducible (7)

Exploitability

Low barrier if encryption is absent (7)

Affected Users

It affects all users that are relying on the database (10)

Discoverability

Tools like Wireshark can easily be used for monitoring making it easier for detection. (6)

DREAD Score Calculation

$$8+7+7+10+6/5 = 7.6$$

Threat: Usage of DNS Spoofing

Damage

If traffic is redirected all data may be compromised which could lead to financial and legal liability. (8)

Reproducibility

The attacker must develop more on the attack to make it fully reproducible. (6)

Exploitability

An attacker has a level of skill to exploit the threat (7)

Affected Users

It affects all users that are relying on data (10)

Discoverability

reconnaissance is necessary (6)

DREAD Score Calculation

$$8+6+7+10+6/5 = 7.4$$

Branch 2: Intercept Data Traffic

Threat: Set Up a Man-in-the-Middle Attack

Damage

Data being intercepted will influence and jeopardize confidentiality and integrity.
(8)

Reproducibility

Requires network path to be Fully reproducible (6)

Exploitability

Skills are required to exploit this threat (7)

Affected Users

It affects all users that are relying on the database (10)

Discoverability

Detection tools Like XArp that discover MITM Attacks. (6)

DREAD Score Calculation

$8+6+7+10+6/5= 7.4$

Branch 3: **Exploit Database Connection**

Threat: Exploit Misconfigured Authentication

Damage

Data breaches occur due to access to the database. (8)

Reproducibility

Flaws are easily exploited once found (8)

Exploitability

An attacker must have Misconfiguring skills at a certain level to exploit
(6)

Affected Users

It affects all users that are relying on data (10)

Discoverability

Can not be easily found without access to internal configurations (6)

DREAD Score Calculation

$$8+8+6+10+6 = 7.6$$

Branch 3: **Exploit Database Connection**

Threat: Usage of stolen Credentials

Damage

Anyone could have free access to the database with stolen credit. (9)

Reproducibility

Credentials could be reused frequently (10)

Exploitability

Must Requires obtaining legitimate credentials (6)

Affected Users

It affects all users that are relying on data (10)

Discoverability

Can be discovered if logs are inspected (6)

DREAD Score Calculation

$$9+10+6+10+6 = 8.2$$

Conclusion

In Conclusion, my threat model diagram has explored my online education platform the evaluation has presented me with numerous flaws with the SQL database, cloud storage, and payment processing systems. By running a dread and stride report I identified multiple vulnerabilities and proposed many mitigations.

